TASK 4: SOC

1. THREAT HUNTING METHODOLOGIES

1.1 Proactive Threat Hunting:

Threat hunting is defined as a human-driven and hypothesis-based activity where the individual actively hunts for threats in a network or other sources that have bypassed all automatic security defenses. Threat hunting is different from incident response in that incident response deals with known attacks once there is an alert while threat hunting assumes that the attacker is already inside the network.

Proactive Threat Hunting vs. Reactive Incident Response:

- Threat Hunting (Hypothesis-Driven):

Goal: Early detection of potential attacks.

Approach: Begins with an assumption (e.g., "The adversary is using legitimate compromised credentials to move laterally").

Steps: Examines data, examines behavior, and searches for irregularities.

Outcome: Shortened dwell time, timely discovery of threat actors, and generation of new detection techniques.

- Incident Response:

Goal: To isolate, eradicate, and recover from security events.

Trigger: Set off by alerts generated by SIEM, EDR, or other cybersecurity software.

Steps: Examines identified IoCs.

Outcome: Minimizes harm and brings back normal operations.

Hypothesis-Driven Hunting: T1078 - Valid Accounts Misuse:

Credential abuse (using valid credentials) is one technique that adversaries can use to overcome security measures and disguise themselves in regular operations. An effective hunting for such behavior can look like:

- Hypothesis: "The adversary is abusing an account of a user who was logged into his/her system during the past month and is attempting to access sensitive servers via RDP."
- Hunting Methodology (T1078):

1. Look at the Logon Time: Find instances where users have successfully logged into the system after their work hours (e.g., 2 am).

2. Find Out the Anomaly: Find out if there were successful logins from geographic locations where the particular user never logged in before.
3. Check Recent Activity: Find out which account has been accessing servers which he/she never did before.
4. Investigate Activity: Perform a query about the usage of local admin accounts that are inactive.

- Revised Hypothesis: If the anomalies are found, the investigation is to focus on them to see if this activity was malicious or automated.

Example: Hunt for Anomalous Privilege Escalation

Proactive hunting that targets privilege escalation can involve looking for evidence that the account has escalated its permissions to a higher level illegally.

- Hypothesis: "The attackers use the fodhelper.exe UAC bypass method to escalate user privileges to administrator."
- Data Source: EDR process logs.
- Search/KQL Queries:

1. Detecting abnormal parent-child processes: Detect when fodhelper.exe starts cmd.exe or powershell.exe.
2. Unauthorized service modification: Check for services with SYSTEM permissions installed or modified by a user with no admin rights.
3. Token manipulation: Watch out for enabling of the SeDebugPrivilege by a suspicious user process, a common sign of token manipulation attacks.

- Example Log: The user john.doe runs a file that runs fodhelper.exe, which spawns a process cmd.exe that runs whoami /all command right away, showing an Integrity Level of High.

1.2 Hunting Frameworks:

Using threat hunting methodologies enables one to shift from alert fatigue to threat discovery in a systematic manner. In addition, threat hunting methodologies make sure that the hunting exercises are repeatable, measurable, and intelligence-led.

- TaHiTI (Targeted Hunting integrating Threat Intelligence): TaHiTI is a methodology-based framework that seeks to bring together Threat Intelligence (TI) and real-world hunting actions. Its main goal is to ensure that hunts are done in a risk-based way rather than randomly.

TaHiTI Lifecycle:

1. Trigger: The hunt is triggered by one of these factors: a new TI report, risk assessment at the enterprise level, or business needs.
2. Preparation: Set the scope, establish a hypothesis based on TI, and select the required data sources (for example, EDR, network traffic).
3. Execution: Technical hunting happens in this stage. Hunters need to write queries and look for behaviors or indicators.
4. Finalization: Record your results. In case of threat detection, an incident response is started; if no threat is detected, the lessons learned are applied to create automation rules.

Main Advantage: It takes intelligence and converts it into practical hunting “playbooks,” enabling hunters to focus on the right things during the hunt process.

- SqRR (Search, Query, Retrieve, Respond):SqRR is a methodology (usually linked to the original threat hunting philosophy of Sqrrl) which concentrates on the process itself performed by the hunter. Specifically, it covers the sequence of actions a hunter takes while working with data.

The SqRR Phases:

1. Search: Generally analyzing the environment to identify any outliers/anomalies that do not match the "baseline".
2. Query: Formulating the question that should be answered by the data (such as "Show me all powershell execution with an encoded command within the last day").
3. Retrieve: Getting the right data subsets.
4. Respond: Taking the necessary actions, either isolating the infected host or implementing new policies that will not allow such behavior in the future.

1.3 Data Sources for Hunting:

Threat hunting involves the utilization of various types of information sources in order to detect, analyze, and counteract any possible threats. Some of these include EDR for process/file monitoring, network information such as DNS and PCAP for monitoring network traffic, and threat intelligence like MISP for identifying adversary tactics.

Key Datasets Used for Threat Hunting:

- Endpoint Detection and Response (EDR): Telemetry data about process executions, registry key creations/deletions, file creation, and other events from EDR tools. Vital in detecting lateral movement and fileless attacks.
- Network Traffic Logs & Network Detection and Response (NDR): DNS logs, network communications, and even encrypted traffic logs. Critical in detecting Command & Control communications.
- Cloud and SaaS logs: Useful in detecting deviations and anomalies in the cloud environment like unauthorized API access attempts.
- IAM/Access logs: Monitoring user activities and privileged accounts, useful for detecting credential misuse and insider threats.
- Threat Intelligence Feeds: External intelligence that can include IOCs like malicious IPs and file hashes.

Data Integration and Analysis:

- Log Correlation: Effective hunting involves merging these data sources into a SIEM system or a data lake (Splunk, Elastic).
- Automation: The application of automated methods in processing big data enables investigators to concentrate their efforts on analyzing data.
- Approaches: Investigators utilize the collected data sources in searching for any malicious activities, such as abnormal user-agents or programs run from temp folders.

1.4 Threat hunting case study:

APT29 (Nobelium/Cozy Bear) is a complex threat actor group that specializes in attacks against cloud-based systems and software supply chains.

- TTPs: The use of stolen credentials by APT29 to add additional users in the Azure AD environment is prevalent.
- Detection: Hunters use MITRE ATT&CK framework to detect APT29's laterally movements and command & control communications (residential proxies for masking communications).
- Hypothesis: "APT29 has penetrated via the vulnerability of third-party software applications." The hunt process may start with searching for anomalies in API calls/newly created users in the Azure AD environment using Elastic SIEM.

2. ADVANCED SOAR AUTOMATION

2.1 SOAR Components:

Security orchestration, automation, and response (SOAR) solutions allow security teams to handle security incidents by integrating three critical features. The first is Orchestration, which refers to the integration of various security systems; the second is Automation, which refers to the execution of automated processes without any human involvement; while the third is Response.

- Security Orchestration (Workflow Integration): Orchestration becomes the master conductor, bringing together various security tools like SIEM, firewalls, EDR, and threat intelligence feeds into a comprehensive API-driven process.

1. Workflow Integration: Rather than having to toggle between different tools (the swivel-chair problem), SOAR brings these tools together, enabling information exchange within the security environment.
2. Playbooks: Security orchestration relies on "playbooks," which outline the steps required to deal with certain incidents (for instance, a phishing incident or suspicious login).
3. Example: When the threat intelligence feed indicates a particular IP address, the security orchestration checks whether there is any network activity through the firewall before updating the case management platform.

- Security Automation (Execution of Tasks): Automation involves performing certain repetitive, low-level, and time-intensive tasks without human involvement to minimize human effort and save time.
    1. Auto-Ticketing: Once alerted by a SIEM, the SOAR solution will automatically create a ticket (ServiceNow, Jira) and then prioritize and assign that task to an analyst based on severity level.
    2. Alert Enrichment: This is where the automation process automatically enriches the alerts by collecting information about the artifacts involved without the need of the analyst; for instance, a URL can be checked via VirusTotal and a user account in Active Directory.
    3. Example: A playbook will automatically parse emails in order to look for IOCs such as malware hashes or IP addresses.
- Security Response: A response refers to actionable activities carried out to contain, eradicate, and recover from a security issue. The response process may be totally automated or semi-automated.

1. Auto-Containment: SOAR can immediately respond to security threats by activating actions within applications such as the isolation of an infected laptop using EDR or blocking of a harmful domain using the firewall.
2. User Remediation: Automated processes may include changing of passwords or account deactivation of the affected users.
3. Example: If there is a successful phishing attack, a response activity may involve automatic deletion of the malicious email from the mailboxes of all users and blocking the attacker's domain and performing a malware scan on the recipient's computer.

2.2 Playbook Development

Creating a playbook refers to establishing procedures that can be followed during an incident. An effective playbook requires little manual labor, guarantees consistent management of incidents, and lowers the time needed to resolve incidents.

Key Stages of Playbook Design:

Effective playbooks follow the NIST incident response lifecycle:

1. Preparation: Define the incident type and gather necessary credentials for integrations (e.g., Firewall, EDR, Email API).
2. Detection & Analysis: Use SIEM alerts to trigger the playbook. Enrich the data by analyzing indicators of compromise (IoCs).
3. Containment & Eradication: Automate actions to block threats and quarantine affected systems.
4. Recovery & Post-Incident: Re-enable systems and document lessons learned.

Example: Automation of IP Block for C2 Traffic (Malware)

This example is all about automation of the isolation of C2 traffic to prevent the malware from leaking.

Automated Workflow:

1. Trigger: The Security Information and Event Management system (SIEM), like Microsoft Sentinel, identifies outbound traffic towards a malicious C2 IP.
2. Enrichment: Automatic querying of firewall logs for identifying the source internal IP of the affected device.
3. Action - Network Isolation: Trigger API calls to NGFW (Next Gen Firewalls, like Palo Alto or FortiGate) to add this IP to the blocked Dynamic Address Group.

Commit firewall changes.

4. Action - Isolation of endpoint: Call the endpoint detection and response platform (EDR, such as CrowdStrike, Defender) to isolate the affected endpoint.
5. Notification: Update the incident report ticketing platform (JIRA, ServiceNow).

2.3 Integration with SIEM/EDR:

It is necessary to integrate SOAR with SIEM and EDR technologies, such as Wazuh or Elastic Security, as this would facilitate streamlined processes, avoid alert fatigue, and increase speed of response. Through SOAR integration, disjointed and manual security tasks will be transformed into efficient, streamlined workflows.

- Integration with Wazuh (SIEM/XDR)

Wazuh, a SIEM and XDR platform, has native capabilities for integration with SOAR solutions (such as Shuffle or TheHive), providing automated incident handling and orchestration.

1. Description: In this approach, Wazuh agents collect data from endpoints, while Wazuh server identifies security threats and creates alerts based on that. The alerts generated by Wazuh (e.g., failed login attempts, file integrity change) are delivered to the SOAR solution via webhooks and triggers playbooks execution.
2. Use Cases:

- Threats containment: Wazuh discovers an attack from an IP address, and it triggers the SOAR platform to execute an Active Response playbook that contains instructions for isolation of the endpoint via firewall rules.
- Incident enrichment and investigation: Once an alert from Wazuh is received, a SOAR solution automatically enriches it with data from threat intelligence sources (e.g., VirusTotal) and performs further actions depending on its findings.
- Automated password rotation: If an attacker has gained access to the environment, an automatic password rotation of the affected user's account (e.g., AWS IAM account) can be implemented via playbooks.

3. Integration Details: Shuffle has native support for Wazuh, which integrates SOAR platform with Wazuh via webhooks. Such integration provides filters (e.g., forward all events where level > 3).

- Integration with Elastic Security (SIEM/EDR)

Elastic Security features a built-in solution for SIEM, EDR, and automation capabilities. A "native SOAR" feature exists through "Elastic Workflows," which means that you don't have to use complex and additional integration tools.

1. How it Works: Within the Elastic Security software there exist "Responder" functionality and playbooks that respond immediately upon receiving any detection alerts in the Kibana application.
2. Important Workflows:

- Automated Phishing Response: With the help of the SOAR playbook, the software extracts the dangerous URL or the sender's domain from the phishing alert and, after checking the intelligence sources, blocks it automatically on the network firewall.
- Automated Endpoint Isolation: If Elastic EDR detects malware, the software instantly isolates the problematic machine from the corporate network.
- Ticketing: Upon receiving the alert, Elastic opens, closes, and updates the ticket automatically in any external system such as ServiceNow or TheHive.

2.4 Automation Case Study

- Context: A large company receives thousands of phishing emails. It takes up a lot of analysts' time to analyze emails manually in terms of header, malicious URL, and attachment. This causes huge MTTR.

Phishing Playbook Automation Workflow:

1. Ingestion/Triage: Either user marks suspicious email (with one click) or email gateway detects some threats. In that case, the SOAR solution will generate a ticket.
2. Extraction/Enrichment: SOAR solution will analyze an email and extract header, malicious URLs, and attachment. It will ask reputation information of all extracted information from threat intelligence platforms like VirusTotal or Domain Tools.
3. Analysis/Detonation: If the attachment is unknown, SOAR solution will put it into sandbox for detonation and analyze its behavior.
4. Containment/Mitigation:

- If the attachment is malicious, SOAR will remove that email from all users.
- Blocking malicious IPs/URLs on firewalls.
- If the user clicked the link, the system isolates the infected machine using EDR solution.

5. Closure/Reporting: The playbook will document this process. Then notify the user reporting that email about results of this investigation.

SOAR Implementation Guidance by CISA: The CISA Guidance, as well as the observations by the Australian Cyber Security Centre (ACSC), stresses that SOAR cannot be treated as a "set and forget" solution.

- Baseline Creation: A baseline of typical network activity needs to be created to distinguish between benign and threatening actions.
- Playbook Management: Playbooks need to be continuously managed, else their fixed nature will make them obsolete.
- Balanced Model: Automation should supplement human efforts rather than supplant them; automation performs routine duties while human decision-making addresses more complicated situations.

3. POST-INCIDENT ANALYSIS AND CONTINUOUS IMPROVEMENT

3.1 Root Cause Analysis (RCA)

A Root Cause Analysis (RCA) involves using methods such as the 5 Why approach and the use of fishbone diagrams to identify the root cause of any problem, enabling institutions to solve any issues rather than treat their symptoms. This analysis helps to prevent future problems by addressing the failure in the process or system.

RCA Techniques:

- 5 Why's: An iterative approach consisting of asking why about a certain problem approximately five times in order to examine its underlying cause and effect relationship.
- Fishbone Diagram or Ishikawa Diagram (Cause-and-Effect Analysis): A chart which helps in categorizing the possible causes of a problem (i.e., People, Process, Technology, and Material).

Example: RCA for a Phishing Attack

Context: A firm has undergone a data breach in which one of its employee fell victim to a phishing attack. As a result, his credentials have been breached, and he accessed a restricted database.

Solution: The 5 Whys Analysis

- Problem: An employee clicked on a phishing link.

1. Why has he done it? He considered the email to be a normal invoice request and didn't think it might be a fraud.

2. Why did he believe so? The email looked credible and was not flagged by the system.
3. Why wasn't it flagged? The filter allowed this particular type of email to come through because of the filter's low strictness setting.
4. Why were there such settings? They were used in order to avoid any unnecessary restrictions of the company's contacts.
5. Why were those settings acceptable? There was no appropriate policy review for them.

- Root Cause: The lack of a comprehensive policy review process for email security filters.
- Countermeasure: Tighten all security policies for emails and add threat detection features to them.

The steps of Conducting an RCA include the following:

1. Problem Definition: This is developing a statement of the problem that is clear, specific, and measurable.
2. Data Collection: Data collection can include collecting facts, logs, interviews, and timelines.
3. Possible Causes: Brainstorm or draw a fishbone diagram that lists all the possible causes for the problem.
4. Root Cause Analysis: This step uses the 5 Whys analysis to determine the cause.
5. Corrective Action Implementation: The problem needs to be solved by finding the actual cause.
6. Effectiveness Verification: Solutions need to be verified and confirmed as working.

3.2 Lessons Learned Process:

The post-mortem (lessons learned) approach refers to a systematic examination conducted after completing a project. It entails identifying factors that contributed to success, those that contributed to failure, and areas for improvement in subsequent projects. Through projects, organizations can learn valuable lessons that help streamline processes and enhance outcomes in the future.

Key Process for Conducting Post Mortem Analysis:

A successful post-mortem will follow 5 critical steps including identification, documentation, analysis, storage, and retrieval.

1. Preparing & Gathering Data (Prior to the Meeting): Send out a questionnaire to key stakeholders prior to the meeting in order to prevent the forgetting of any important

information. Refer back to the original objectives of the project, budget and timeline of the project.

2. Meeting:

- Setting the Tone: Set up the tone by creating a no-fault atmosphere where learning takes place and finger-pointing is discouraged.
- What Went Right: List down all the positive points of the project and discuss what could be used again.
- What Went Wrong: Talk about negative aspects and carry out root cause analysis (for example 5 Why method).
- Improving: Brainstorm on how to improve tools, processes and training, if needed.

3. Documentation: Write down your results and action plan including actions to take, responsible persons and deadline.
4. Storage & Sharing: Store all results in a searchable repository.
5. Application & Retrieval: Review lessons learned before beginning a new project.

Steps to Enhance Process, Tools, and Training:

It is crucial to ensure that lessons learned lead to actual enhancements in processes at the firm.

- Process Improvements: Determine areas where there are loopholes within the existing process (e.g., in communications). Revise or come up with new SOPs.
- Tools Improvements: Determine whether the tools being used are sufficient. In case the technology has caused delays, the post-mortem should help determine a way forward through new software.
- Training: Lessons from both failure and success should be utilized to prepare training manuals for new hires.

Best Practices for a Successful Post Mortem:

- Continuous Learning: Perform a lessons learned discussion at critical stages of the project and not just the end of the project.
- Psychological Safety: Create an environment where members can freely discuss their failures without being blamed.
- Focus on Action Items: Identify 2-3 important action items that can be acted upon, not a never-ending list of problems.
- Post Mortem Checklist/Templates: Adopt checklists/templates to streamline the process.

3.3 Metrics and KPIs:

Metrics such as MTTD and MTTR are essential for SOC performance measurement and minimizing risks. The MTTD metric is aimed at the average time spent to discover threats; the MTTR metric, in its turn, evaluates the rate of containment and resolution, which depends on team efficiency.

Main SOC Metrics and KPIs to Track:

- Mean Time to Detect (MTTD): Average time it takes to identify an attack or threat in the network, which helps in evaluating the performance of security tools.
- Mean Time to Respond/Mitigate (MTTR): Average time required to mitigate an identified threat or attack in the network.
- Mean Time to Investigate (MTTI): Time required by an analyst to begin investigations regarding any threat.
- False Positive Rate (FPR): Percentage of alerts generated that do not turn out to be a threat; higher FPR means inaccurate results.
- Dwell Time: Amount of time it takes for an attacker to go unnoticed once he has been detected in the network.
- Incident Closure Rate: Ratio between total incidents investigated versus those closed or resolved by the team.
- Detection Capability: Percentage of adversary techniques (MITRE ATT&CK framework) that can be detected by the system.

4. ADVERSARY EMULATION TECHNIQUES

4.1 Adversary Emulation:

Adversary Emulation is an active security assessment process based on intelligence about potential threats. It relies on TTPs used by actual adversaries and differs from traditional penetration testing in the way that while penetration testing involves discovering any weakness in the system, adversary emulation tests the ability of the Security Operations Center to detect and respond to multi-stage attacks.

TTPs of Adversary Emulation:

Adversary emulation employs particular MITRE ATT&CK TTPs to simulate an accurate environment.

1. T1566 – Phishing (Initial Access)

Phishing is one of the ways through which adversaries attain initial access by persuading the victim to share credentials or run malicious codes.

Sub-TTPs:

- T1566.001 (Spearphishing Attachment): Emails sent by adversaries that have attached malicious documents such as Office document with macros, PDFs, and ZIPs.
- T1566.002 (Spearphishing Link): Adversaries will craft emails that contain links leading the users to malicious websites or cloud computing environments where they can download malware that cannot be detected by scanning for attachments on emails.
- T1566.003 (Spearphishing via Service): This TTP occurs when adversaries initiate communication via third-party communication applications such as LinkedIn, Slack, or Teams.

Approach for Emulation: Phishing can be performed using phishing-as-a-service or social engineering tactics.

2. T1210 - Exploitation of Remote Services (Lateral Movement)

Upon gaining access, the attacker exploits any remote services to laterally move from the compromised machine to other machines within the network.

- Target: There are many common vulnerabilities in services including but not limited to SMB, RDP, MySQL, Web Servers or VMware vCenter.
- Methodology: The adversary searches for vulnerabilities, misconfiguration, or network service that can provide an attack surface allowing the remote code execution on the target.
- Emulation Technique: Use Metasploit to emulate exploiting the vulnerable service or netsh command for port forwarding and lateral movement.

SOC Detection and Response Testing

Adversary emulation covers all phases of the incident response life cycle:

- Detection and Analysis:

Phishing attack: Can SOC discover the malicious link/hash through email security gateway/SIEMs? Does SOC observe suspicious user activity?.

Exploitation: Do SOC sensors detect any anomalies in the child process created under the service processes like web server or any new outbound connection (C2 Callback)?

- Containment: How fast can SOC isolate the machine using EDR or block any malicious IP/domain?

- Eradication and Recovery: Is it possible to eliminate any malicious artifact, clear registry entries, and patch the exploited application?.

Tools and Frameworks:

- MITRE Caldera: Automated adversary simulation tool.
- Picus Security/Pentera: Automated red teams.
- Red Team Notes: Command resources such as netsh for lateral movement

4.2 Emulation Frameworks:

MITRE Caldera is an adversary simulation system that is open source in nature and enables users to test their defensive capabilities by automating the simulation of attacks through actual threat behaviors. The tool is based on the MITRE ATT&CK Framework and lets users create operations or automated attacks.

Key Components of Caldera:

- Core: Asynchronous Command and Control (C2) server with REST API and GUI.
- Agent: Software deployed on targeted systems (Windows/Linux) that receives and carries out commands; examples include Sandcat and Manx, each offering distinct features.
- Plugin: Extra components that enhance the system's functions; examples include Atomic Red Team, a plugin that incorporates Atomic Red Team test cases.

Example: Simulating Spearphishing Attack

In order to evaluate the email filtering and Endpoint Detection and Response (EDR) systems against a spearphishing attack via the use of Caldera, the following steps may be followed to simulate the post-compromise activities following the click on the phishing link.

1. Scenario Planning (Pre-Computation)

Prior to using Caldera, a "phish" (such as a macro-enabled Word document or a questionable link) needs to be developed. The objective for conducting such simulation would be to determine whether the corporate email filtering system catches it and if the EDR identifies the secondary payload generated as a result of it.

2. Using Caldera to Simulate the Attack

Steps to Conduct Simulation using Caldera:

- Prerequisites: Setup a Caldera agent (e.g., Sandcat) on the test system.
- Initial Access: Imitate a victim accessing the "phishing" file.

- Execution (T1204 - User Execution): The agent would execute a command to download the second stage malware from the Caldera C2 server.
- Command and Control (T1071 - Application Layer Protocol): The agent would send signals to the C2 server over HTTP/HTTPS protocol mimicking the callback from the payload.
- Defense Evasion (T1027 - Obfuscated Files or Information): The tool can use obfuscated PowerShell script to evade signature detection.

3. Evaluation and Reporting

After the test completes, Caldera delivers an evaluation report that identifies which actions were inhibited, discovered, and failed.

- Indicator of Success: The email filter inhibits the attachment, or the EDR terminates the process at the endpoint.
- Indicator of Failure: Malicious code runs, achieves persistence, collects system information, and doesn't trigger any alerts.

Benefits for Security Teams:

- Automation: Saves time in labor-intensive manual red teaming efforts.
- Validation: Demonstrates that security controls work.
- Training: Assists blue teams (security personnel) understand the tactics employed by attackers.

4.3 Red-Blue Team Collaboration:

Red-Blue team cooperation, commonly known as purple teaming, acts as an important link between offensive imitation and defensive execution by creating a cycle for constant improvement in security. In this process, the Red Teams act as "the attacker's vote" that identifies the effectiveness of the defensive measures and the detection rules applied.

Emulation and its Impact on Strategy:

The practice of Red teaming through emulation turns the defensive strategy into something more threat informed rather than simply following the principles of compliance.

- Verifying Attack Paths: By way of example, Emulation can reveal how small weaknesses, like poor passwords or overly open file shares, may be combined to gain access to key business information.

- Assessing Human and Process Weaknesses: Unlike scanning tools, which simply run their automated programs, manual emulation allows for testing of the organization's social engineering weaknesses and response protocols.
- Remediation Prioritization: With these results, organizational leadership is able to better prioritize remediation efforts towards exploits which pose an immediate threat to the business.

Improving Detection Rules:

The collaborative process improves the technical ability of Blue Teams through engineering input.

- Behavioral Detection: The exercises push the defenders to shift from signature-based detections to behavioral detections for tactics, such as using PowerShell abnormally, moving laterally, and exfiltrating data.
- Finding Gaps: In real time, it highlights gaps, indicating that certain techniques, such as a specific type of credential dumping, leave no footprint on the current logging framework.
- Tuning of Detection Rules: The Blue Team can tune their existing Security Information and Event Management (SIEM) and Endpoint Detection and Response (EDR) rules using emulation data to reduce false positives and ensure high-fidelity alerts for the relevant adversary tactics, techniques, and procedures (TTPs).
- Validation: Maturity in an organization involves the use of automated Breach and Attack Simulation (BAS) technology to test and ensure that any detection rule fixed continues to stay relevant and does not "drift."

Collaborative Frameworks:

The MITRE ATT&CK Framework is often leveraged by organizations as the common language. Red teams align their attacks according to the framework matrix, which enables Blue Teams to determine precisely what was detected at each step in the Cyber Kill Chain.

5. SECURITY METRICS AND EXECUTIVE REPORTING

State-of-the-art SOC metrics analyze SOC performance based on how fast alerts can be detected, how efficient responses are carried out, and how accurate alerts are made. Some of the most critical SOC metrics include lowering dwell time, cutting down the number of false positives to alleviate alert fatigue, and reducing MTTR.

5.1 Advanced SOC Metrics:

Advanced SOC Metrics to Measure Effectiveness:

- Dwell Time (Mean Time to Detect – MTTD): Determines the mean time that a threat remains undetected. Shortening dwell time is important for limiting the attack's "blast radius."
- Mean Time to Respond (MTTR): Measures the response rate from detecting a threat to isolating and remedying it.
- False Positive Rate (FPR): Refers to the percentage of false alerts reported by the SOC's incident detection system. A high FPR may cause burnout among analysts and prevent the detection of actual threats.
- True Positive Rate (TPR): Indicates the percentage of security alerts that turn out to be true incidents.
- Incident Escalation Rate: Calculates the percentage of cases that must be escalated to more experienced analysts.
- Mean Time to Containment (MTTC): Concentrates solely on the time it takes to contain a threat.

Effect on SOC Strategy:

- Increased Transparency: Provides insight into areas for improvement regarding tools used and potential risks involved.
- Increased Efficiency: Identifies, via higher rates of false positives, monitoring solutions that require adjustments.
- Automation Metrics: Sophisticated SOCs employ KPIs unique to the use of AI, like automated action percentages and time savings for analysts, to assess the effectiveness of automation.
- Prioritization: Assists in redirecting attention from output metrics, like alert volume, to outcome-based KPIs.

5.2 Executive Reporting:

In order to communicate technical metrics related to incidents to non-technical audiences, one must be able to translate the information provided into a business perspective that concentrates on the effect that it will have on the user. Good executive reporting involves translating technical metrics into a meaningful story.

1. Critical Metrics for Executive Dashboards

Executives care more about user experience, business impact, and dollars than about the technical cause.

- Mean Time to Repair (MTTR): Length of time until service recovery based on overall downtime.
- Business Impact Metrics: Percent of impacted users, financial impact, or failed transactions rather than CPU utilization or errors.
- Service Availability (SLA/SLO): Actual uptime compared to target displayed graphically to demonstrate compliance with service level agreements.
- Incident Volume Analysis: Six-month trend of incidents opened vs. incidents closed.

2. Visualizations for Leadership

Do not rely on detailed spreadsheets. Create visualizations that enable stakeholders to comprehend essential information within a few seconds.

- Status Dashboards (Red/Amber/Green): Adopt RAG (Red/Amber/Green) dashboards to provide an instant indication of service status.
- Graphical Trends: Create trend line graphs to indicate the number of occurrences over time.
- Bar Graphs: Categorize the number of occurrences based on their criticality (Low/Medium/High/Critical).
- Heat Maps: Indicate the number of occurrences by services/department with a high occurrence rate.

3. Formulating the Story: "The Story"

Connect the technical and business aspects by forming the story on the basis of context, impact, and action.

- Begin With the Bottom Line: Begin with the key point or lesson (for instance, "The service resumed in 2 hours affecting 5% of the customers").
- Form Analogies: Illustrate technical concepts using analogies (for instance, database problems are described as being similar to "a clogged pipe in a plumbing system").
- Ask Why: Mention why you implemented a patch as "to protect user data" and not "to run a Git commit on the SQL vulnerability."
- Apply the 10-7 Rule: Select the 10% of the most vital information and state it 7 times instead of explaining all the 100% of technical information.

4. Organizing the Executive Summary Report

The one page executive summary report must include the following information:

- Summary/Executive Overview: Executive summary about the problem.
- Impact on Business: Users/services/business affected by the issue.
- Key Metrics: Status (Resolved/In Progress/Under Investigation), MTTD, and MTTR.
- Action Taken/Current Status: A chronological sequence of events that have taken place.
- Preventive Measures/Lessons Learned: Steps being taken to avoid future occurrences.

5. Best Practices for Delivery

- Use Clear Language: Remove jargon from your communication.
- Express Clarity: Make sure to distinguish between facts, unknowns, and verification.
- Offer Time Frames, Not Deadlines: Rather than saying "it will be resolved in 30 minutes," say "we will provide our next update in 30 minutes."
- Encourage Engagement: Ask "What is on your mind?" openly and freely while discussing things.

5.3 Continuous Improvement:

Continuous improvement in information technology operations as well as security (SecOps) is achieved through the use of metrics to determine any deficiencies in the operations including poor detection and repair times. Using KPIs helps one move from being a detective to becoming proactive.

Gaps Through Metrics:

- High MTTD (Long Time to Detect): This suggests inadequate monitoring, too many false alarms for analysts to handle, or no detection policies implemented.
- High MTTR (Long Time to Repair): This may mean lengthy triage, poor documentation, manual processes, or lack of skill among the workforce.
- Low Detection Scope: Missed alerts point to gaps in tool coverage, such as failure to use EDR or access cloud logs.
- High Alert Fatigue: False alarms overwhelm analysts, leading to missed threats.

Solutions Proposed to Fill the Gap:

1. Reduce MTTD (Faster Detection)

- Automation: Employ automation via machine learning and behavior-based detection capabilities to detect threats faster than rules-based methods.
- SIEM/Logging Optimization: Optimize the use of your SIEM tool in order to minimize false positives and maximize signal-to-noise ratio.

- Higher Rate of Monitoring Checks: Lower the frequency of monitoring checks from 5 minutes to 1 minute for critical endpoints.
- Visibility Improvements: Ensure the full EDR capability is in place and streamline your tools to improve visibility.

2. Reducing MTTR (Speed Up Response and Remediation)

- Incident Response Automation: Automate incident response processes using SOAR capabilities and automate repetitive tasks.
- Playbooks: Build and implement playbooks that document responses to recurring attacks.
- Contextual Alerting: Utilize alerts that can give you contextual information on the impacted system and user behavior.

3. Improvements Focused on Process

- Root Cause Analysis After Incidents: Perform detailed root cause analysis to pinpoint the precise location of any delays.
- Perform Security Drills: Apply security simulation techniques (pentesting/purple teaming) for training purposes.

Top Five SOC Success Factors:

- Speed of Detection and Response: Low MTTD and MTTR.
- Accuracy: High true positives and low false positives.
- Incident Handling: Efficient handling and solving incidents, not just detecting them.
- Compliance: Compliance with security standards and regulations.
- Analyst Effectiveness: Ability to handle increased workload